SHIVA ZEN

Sistema de Gestão para Clínica de Estética

Jaqueline Aranha Estética

Documento de Requisitos
Requisitos funcionais e não funcionais

Versão 1.1 | 30/10/2026

Sumário

1. Introdução 3
1.1 Objetivo 3
1.2 Escopo do produto 3
1.3 Convenções 3
1.4 Origem e manutenção 3
2. Atores 4
3. Requisitos funcionais 5
3.1 Cliente e visitante do site 5
3.2 Equipe (ADMIN e profissional) 5
3.3 Administração (ADMIN) 6
3.4 Profissional 7
3.5 Sistema e integrações 7
4. Requisitos não funcionais 8
4.1 Segurança 8
4.2 Privacidade 8
4.3 Confiabilidade 8
4.4 LGPD 9
4.5 Integridade 9
4.6 Desempenho 9
4.7 Observabilidade 9
4.8 Qualidade 10
4.9 Usabilidade 10
4.10 Manutenibilidade 10
4.11 Implantação 10
4.12 Documentação 11
5. Casos de uso 12
6. Matriz de rastreabilidade 14
7. Resumo 16

1. Introdução

1.1 Objetivo

Este documento reúne os requisitos do Shiva Zen: o que o sistema faz para cada ator (requisitos funcionais, RF) e as qualidades que ele precisa ter — segurança, privacidade, confiabilidade, desempenho, usabilidade, manutenibilidade, implantação e documentação (requisitos não funcionais, RNF). Cada RF aponta os casos de uso que o realizam e as regras de negócio que o governam; cada RNF diz como é verificado (teste automatizado ou etapa do CI).

1.2 Escopo do produto

Plataforma web da clínica: site público com catálogo e agendamento online (a cliente prova o celular por código SMS, sem senha), área "Meus agendamentos", links individuais (confirmar presença, ficha de anamnese, termos, NPS), portal da profissional, painel administrativo (agenda, pedidos, clientes e prontuário, catálogo, pacotes, promoções, comissões, financeiro, NPS, termos, usuários e auditoria), rotinas automáticas por cron e integrações de SMS, WhatsApp, e-mail, push e captcha. Fora do escopo: pagamento online, emissão de nota fiscal e aplicativo nativo.

1.3 Convenções

Item	Significado
RFnn	Requisito funcional — comportamento observável por um ator.
RNFnn	Requisito não funcional — qualidade do sistema, com a forma de verificação.
UCnn	Caso de uso (diagramas e especificação no documento geral do TCC).
RNnn	Regra de negócio (documento de Regras de Negócio).
Essencial	Sem ele o sistema não cumpre o objetivo (agendar, atender, cobrar) ou descumpre a LGPD.
Importante	Necessário para a operação do dia a dia; há contorno manual, com custo.
Desejável	Melhora a experiência ou a gestão; o sistema funciona sem ele.

1.4 Origem e manutenção

Os requisitos foram levantados com a dona da clínica a partir do fluxo real de atendimento e conferidos contra o código: cada RF existe numa tela, rota ou rotina, e cada RNF é cobrado por teste automatizado ou etapa do CI. A fonte é docs/_dados_requisitos.json, a mesma do documento geral do TCC; este documento é gerado dela.

2. Atores

Ator	Descrição
Visitante / Cliente (público, sem login)	Navega no site e agenda sem conta: a identidade é o celular, confirmado por código SMS em todo agendamento. Aceita a Política de Privacidade, o consentimento para dado de saúde e os termos do procedimento, escolhe as autorizações de comunicação, entra na lista de espera e responde NPS por link. Precisa ter 18 anos ou mais.
Cliente cadastrada	Cliente com cadastro ativo (mesmo celular). Entra em "Meus agendamentos" por celular ou e-mail (o código vai ao celular do cadastro) ou direto ao fim do agendamento online, reagenda (até 24 h antes) e cancela pela sessão do portal (com menos de 24 h de horário aprovado conta falta), confirma presença pelo link do lembrete D-1, aceita termos pendentes e exerce os direitos LGPD (preferências, revogação do consentimento de saúde, pedido de correção/exclusão, exportar dados sem a ficha de saúde, descadastrar).
Profissional	Usuário PROFISSIONAL vinculado a um profissional ativo, com 2FA obrigatório em produção. Usa o portal /profissional/: agenda própria, aprova/rejeita os próprios pedidos, marca realizado (com termo aceito ou override auditado), anota a sessão e lê a ficha só das clientes com vínculo. Gera o link do feed iCal, ativa o push e consulta as próprias comissões.
Administrador (ADMIN)	Usuário ADMIN (is_staff), com 2FA obrigatório. Painel completo, incluindo as tarefas de recepção: agenda, agendamento interno, aprovação, clientes, autorizações de comunicação e prontuário, profissionais e exceções de agenda, catálogo, pacotes, promoções, financeiro, comissões, NPS e depoimentos, lista de espera, formulários e termos, usuários, configurações, Branding e auditoria.
Sistema / Cron externo	Serviço Cron do Railway (rodar_jobs_devidos a cada 15 min, horários na JOB_AGENDA) ou agendador externo que chama POST /cron/run/<job>/ com o header X-Cron-Token, ou o comando rodar_job no servidor: fila de e-mail, lembrete D-1, sem desfecho, NPS, alerta de detrator, pacotes, aniversário, limpeza de status, retenção LGPD, housekeeping e feriados. Sem Celery.
Serviços externos	Zenvia (SMS/OTP e status de entrega), WhatsApp Cloud API (lembrete, NPS, aviso de vaga e respostas — nota e "PARAR" — via webhook assinado), provedor de e-mail, Cloudflare Turnstile e Sentry.

A cliente nunca é usuária do sistema: identifica-se pelo celular, verificado por código SMS. A equipe tem dois papéis — ADMIN (dona/recepção, painel completo) e PROFISSIONAL (portal próprio) —, ambos com segundo fator (TOTP) obrigatório em produção.

3. Requisitos funcionais

3.1 Cliente e visitante do site

ID	Requisito	Ator	Prioridade
RF01	Consultar serviços, equipe, promoções (com o mesmo preço do agendamento), galeria e depoimentos autorizados.	Cliente (público)	Essencial
RF02	Agendar online escolhendo procedimento, data/horário e profissional, confirmando o celular com código SMS (até 3 horários futuros ativos pelo site); em dia sem horário, pedir aviso de vaga já preenchido.	Cliente (público)	Essencial
RF03	No agendamento, aceitar a Política de Privacidade e os termos do procedimento, consentir o uso do dado de saúde (termo SAÚDE), escolher as autorizações de comunicação e responder a ficha de anamnese.	Cliente (público)	Essencial
RF04	Acessar "Meus agendamentos" com celular ou e-mail cadastrado (código sempre ao celular) — ou direto ao fim do agendamento online, sem novo SMS — e ver agendamentos futuros e passados, retornos a combinar e o código de indicação; sair só por POST.	Cliente (público)	Essencial
RF05	Reagendar um atendimento até 24 h antes pelo portal, escolhendo novo horário disponível.	Cliente (público)	Essencial
RF06	Cancelar um atendimento futuro pelo portal, com o aviso de que, com menos de 24 h de um horário aprovado, o cancelamento conta como falta.	Cliente (público)	Essencial
RF07	Confirmar presença ou cancelar pelo link do lembrete D-1 (WhatsApp ou e-mail), com o mesmo aviso de cancelamento tardio.	Cliente (público)	Importante
RF08	Aceitar termos pendentes pelo link do atendimento.	Cliente (público)	Importante
RF09	Entrar na lista de espera sem criar cadastro (nome, celular, procedimento, data, turno e profissional opcionais; captcha, honeypot e limite diário por IP) e, com o celular verificado, receber o aviso de vaga por e-mail/WhatsApp, continuando na fila até a data passar ou agendar.	Cliente (público)	Importante
RF10	Responder o NPS (0–10) e autorizar a publicação do depoimento.	Cliente (público)	Importante
RF11	Responder ficha de anamnese por link, com consentimento para dado de saúde.	Cliente (público)	Essencial
RF12	Baixar os próprios dados (DSAR, sem a ficha de saúde) com código SMS em "Meus dados", descadastrar-se de marketing e pesquisas por link e parar as mensagens de WhatsApp respondendo "PARAR".	Cliente (público)	Essencial
RF39	Em "Meus agendamentos", mudar as próprias preferências de comunicação (promoções por e-mail, lembrete e pesquisa por WhatsApp), com o estado vigente à vista e o registro com origem PORTAL.	Cliente (público)	Importante
RF40	Revogar o consentimento de dado de saúde pelo portal (ou a equipe, a pedido, pelo Django admin com motivo), com trilha e o aviso de que a ficha feita fica pelo prazo de guarda.	Cliente (público) / ADMIN	Essencial
RF41	Pedir correção ou exclusão dos dados pelo portal: o pedido fica na auditoria com o prazo de resposta (15 dias) e vai por e-mail à clínica (encarregado > e-mail do administrador > e-mail da marca).	Cliente (público)	Essencial
RF42	Baixar os próprios dados pelo portal (sem a ficha de saúde), exigindo código confirmado há até 10 minutos.	Cliente (público)	Essencial
RF43	Enviar mensagem pelo formulário de contato, com aceite da política, captcha, honeypot, 5/min e 20/dia por IP e teto diário global; sem caixa de marketing; se o e-mail não sair, a página mantém o texto e oferece o WhatsApp.	Cliente (público)	Desejável
RF47	Consultar as perguntas frequentes por categoria na página /duvidas/ (agendamento, pagamentos e pacotes, tratamentos, privacidade e dados), com respostas geradas das regras que o sistema aplica; a página inicial mostra as 5 em destaque e leva para a lista completa.	Cliente (público)	Desejável

3.2 Equipe (ADMIN e profissional)

ID	Requisito	Ator	Prioridade

RF14	Entrar com e-mail e senha, cadastrar e validar 2FA (obrigatório para ADMIN e PROFISSIONAL em produção), gerar códigos de backup e redefinir a senha por link.	Equipe	Essencial
RF19	Registrar e consultar o prontuário (com as perguntas do formulário PRONTUARIO) e o histórico de versões, e anotar as sessões.	ADMIN / Profissional	Essencial

3.3 Administração (ADMIN)

ID	Requisito	Ator	Prioridade
RF15	Aprovar ou rejeitar pedidos PENDENTES (individual ou em lote, item a item: o que outra tela decidiu fica de fora sem desfazer os outros), com e-mail à cliente.	ADMIN	Essencial
RF16	Agendar pelo painel para cliente existente ou nova (cadastrada na mesma transação), com os horários do mesmo cálculo do site, valor do dia ou combinado e e-mail de confirmação à cliente.	ADMIN (recepção)	Essencial
RF17	Operar a agenda: lista com filtros por dia e marcadores em lote, seletor de status só para AGENDADO/CONFIRMADO (Realizado e Faltou só a partir do início), calendário com arrastar-e-soltar (motivo detalhado da recusa), valor cobrado, link do termo, override "Realizado sem termo aceito", desfazer realização e o botão "Agendar retorno" quando o retorno é devido.	ADMIN	Essencial
RF20	Gerir clientes: busca sem acento, ficha com alertas, pacotes, histórico, autorizações de comunicação e edição validada (telefone/CPF/e-mail únicos).	ADMIN	Essencial
RF21	Gerir profissionais (grade semanal, exceções — folga, horário diferente, bloqueio —, antecedências, novo link do feed iCal), procedimentos, preços (vigência nova a partir de hoje), habilitações e bloqueios de agenda (inclusive para todos os profissionais). Desativar a profissional revoga o feed iCal dela; edição que deixaria atendimento futuro sem quem atenda é recusada.	ADMIN	Essencial
RF22	Gerir pacotes: criar/editar o catálogo, vender (itens congelados na venda), acompanhar saldo e validade, cancelar com valor devolvido (reembolso no mês do cancelamento) e prorrogar a validade.	ADMIN	Importante
RF23	Gerir promoções e disparar o e-mail da promoção (período dos atendimentos) em lotes, uma vez, para clientes com consentimento; reenviar só com confirmação.	ADMIN	Importante
RF24	Acompanhar dashboard e financeiro por competência mensal (?mes=: faturamento de avulsos + vendas de pacote − reembolsos do mês, faltas, rankings, últimos 12 meses), comissões em livro-razão (créditos com base e percentual, pagamentos, estornos e saldo por profissional), pagar uma comissão ou o repasse em lote com recibo para imprimir e exportar o Excel gerencial do mês.	ADMIN	Importante
RF25	Acompanhar o NPS e aprovar ou retirar depoimentos do site.	ADMIN	Desejável
RF26	Ver a lista de espera (inclusive as inscrições anônimas, com nome e celular de contato) e avisar manualmente uma vaga: e-mail quando há destino e o aviso registrado mesmo sem e-mail.	ADMIN	Importante
RF27	Gerir formulários (anamnese, pesquisa e perguntas do prontuário) e termos versionados (LGPD, saúde, procedimento), e acompanhar a conformidade dos aceites.	ADMIN	Essencial
RF28	Gerir usuários da equipe (sem trancar a equipe fora; desligamento revoga o feed iCal), as regras operacionais (registro tipado: e-mail do alerta, faltas para pausar o online e anos de experiência do site), a identidade visual (contatos e marca), notificações, pré-visualizar e-mails e consultar a auditoria.	ADMIN	Essencial
RF33	Na ficha da cliente, ver as autorizações de comunicação por canal, revogá-las a pedido e registrar autorização com justificativa (histórico preservado).	ADMIN	Importante
RF37	Gerir as regras de comissão no painel (percentual XOR valor fixo, por profissional e/ou procedimento, com a especificidade e o número de usos à vista); regra já usada só é desativada.	ADMIN	Importante

3.4 Profissional

ID	Requisito	Ator	Prioridade
RF18	Usar o portal: agenda do dia/semana, pedidos pendentes (aprovar/rejeitar), marcar realizado, anotar a sessão, ver alertas de saúde e a ficha das clientes com vínculo, ativar push (novo agendamento, cliente cancelou/remarcou, atendimentos sem desfecho).	Profissional	Essencial
RF34	Gerar o link do feed iCal da própria agenda (exibido uma única vez).	Profissional	Desejável
RF38	Consultar "Minhas comissões" do mês: cada crédito com a base e a regra, o status e o saldo a receber, sem nome de cliente (só leitura).	Profissional	Desejável

3.5 Sistema e integrações

ID	Requisito	Ator	Prioridade
RF13	Oferecer o WhatsApp da clínica como caminho de agendamento quando o SMS não estiver disponível.	Sistema	Desejável
RF29	Executar os jobs periódicos pela agenda única (serviço Cron com rodar_jobs_devidos, cron HTTP autenticado ou rodar_job; job de mensagem no máximo 1×/dia): fila de e-mail, lembrete D-1 (WhatsApp ou e-mail), atendimentos sem desfecho, NPS, alerta de detrator, pacotes, aniversário, limpeza de status, retenção LGPD, housekeeping e feriados.	Sistema	Essencial
RF30	Deixar o retorno gratuito devido (janela em dias) quando o procedimento exige, para a recepção marcar com a cliente — o sistema não reserva horário sozinho.	Sistema	Importante
RF31	Ao mudar o status do atendimento, aplicar na mesma transação: débito de sessão de pacote, comissão (crédito/estorno), cashback, faltas, retorno e aviso à lista de espera.	Sistema	Essencial
RF32	Receber webhooks do WhatsApp (resposta de NPS e pedido de "PARAR") e da Zenvia (status de SMS), autenticados (assinatura da Meta; segredo no header e/ou IP permitido na Zenvia), em tempo constante.	Sistema externo	Importante
RF35	Enfileirar os e-mails transacionais (inclusive o lembrete D-1) na própria notificação e reenviá-los com espera crescente até 5 tentativas.	Sistema	Essencial
RF36	Registrar automaticamente, por trigger, toda alteração das tabelas sensíveis com autor, IP e origem.	Sistema	Essencial
RF44	Exibir a Política de Privacidade a partir do termo LGPD vigente (texto, versão e vigência), emoldurado pela identificação da clínica e do encarregado.	Sistema	Essencial
RF45	Registrar na auditoria a leitura de alertas de saúde na agenda e na visão geral do painel ("Leu alertas de saúde", sem nome de cliente).	Sistema	Importante
RF46	Mostrar no site público só números com dado real — nota média do NPS (com 10+ respostas), clientes atendidas (a partir de 50, arredondadas para baixo), tratamentos agendáveis online e anos de experiência informados pela clínica —, escondendo o que não atinge o mínimo.	Sistema	Desejável

4. Requisitos não funcionais

4.1 Segurança

ID	Requisito	Como é verificado
RNF01	Content-Security-Policy com nonce por request, sem unsafe-inline em script-src/style-src e sem handlers inline; nenhum CDN (bibliotecas de terceiros pelo npm, no bundle do Vite; o único host externo de script é o captcha); frame-ancestors none (exceto o widget).	test_csp; varredura visual do CI (reprova violação de CSP em qualquer rota)
RNF02	HTTPS obrigatório com HSTS de 1 ano (preload), X-Frame-Options DENY, nosniff, COOP/CORP, Permissions-Policy e cookies HttpOnly/SameSite/Secure.	check --deploy com os settings de produção e de staging (job SQLite do CI); test_hardening_final
RNF03	2FA TOTP obrigatório para ADMIN e PROFISSIONAL em produção, conferido a cada request no painel, portal, Django admin e push; códigos de backup; sem tela de login paralela; recuperação só por comando no servidor.	test_2fa, test_auth_equipe, conta/test_dois_fatores
RNF04	OTP com HMAC-SHA256 (OTP_HMAC_KEY ou a SECRET_KEY), comparação em tempo constante, 5 tentativas, propósitos isolados, desafio preso ao telefone e latência mínima no pedido de código do portal e do "Meus dados" (a resposta não revela, nem pelo tempo, quem é cliente).	test_otp, test_token_expiry
RNF05	Rate-limit em camadas: cotas de SMS (telefone, IP, global), limites por IP nos endpoints e formulários públicos (lista de espera, contato com teto diário global, "Meus dados" também por telefone), 30 ações de escrita por minuto por usuário na agenda do painel, django-axes no login; captcha Turnstile no pedido de código, no contato e na lista de espera; honeypot nos formulários sem login.	test_otp, test_contato, test_lista_espera_publica, conta/test_autenticacao, test_auth_equipe
RNF07	Segredos só em variáveis de ambiente, lidas e validadas só nos settings (ruff TID251; .env.example conferido contra o código); SECRET_KEY obrigatória fora de DEBUG; DJANGO_ENV inválido derruba o boot; system checks aranha.W001–W016 apontam configuração de produção faltando e os erros E001–E004 (sem chave de cifragem, sem Postgres, segredo fraco, OTP acima do teto do banco) barram o pre-deploy.	test_deploy_config (env só nos settings, .env.example, system checks), infra/test_deploy; ruff TID251

4.2 Privacidade

ID	Requisito	Como é verificado
RNF06	Áreas privadas sem cache no navegador (no-store), Referrer-Policy same-origin nas rotas com token (o token não sai para outro domínio), X-Robots-Tag noindex nas privadas, Clear-Site-Data no logout; links públicos guardam só o SHA-256 do token; tokens, e-mail, CPF e telefone redigidos no access log, no log da aplicação e no Sentry.	test_hardening_final, test_painel_seguranca_b, test_auth_equipe, test_pii_sentry
RNF22	Dado de saúde cifrado em repouso na aplicação (Fernet, CHAVES_CIFRAGEM com subchave por finalidade e rotação por comando): dump ou backup sem a chave não expõe a ficha.	test_cifragem, test_pg_historico (trilha sem texto claro)

4.3 Confiabilidade

ID	Requisito	Como é verificado
RNF08	Canais de mensagem falham fechado: sem credencial nada é enviado nem marcado como enviado; I/O externo só após o commit; e-mail transacional em fila no banco com reenvio (sem Celery, nada roda em segundo plano sem rastro).	test_fila_email, test_servicos_canais, test_otp (SMS sem credencial não envia)
RNF14	Migrações aplicadas numa transação única com lock_timeout no pre-deploy (tudo ou nada); data migrations com pré-checagem que aborta listando os registros; rollback de produção por restauração do backup.	test_migrations_dados (descem e sobem a cadeia); job Postgres: migrate_atomico do zero; smoke do

		pre-deploy na imagem
RNF15	FSM com transições validadas sob lock e auditadas; efeitos explícitos (services/atendimento) na mesma transação do status; efeitos idempotentes (1 retorno por origem, 1 consumo e 1 crédito de comissão ativo por atendimento, job de mensagem 1×/dia, cashback único).	test_fsm_integridade, test_efeitos_atendimento, test_fluxo_pedido

4.4 LGPD

ID	Requisito	Como é verificado
RNF09	Autorizações de comunicação por finalidade × canal em histórico append-only (texto exibido, IP, navegador, autor); aceite da política, do termo de saúde (art. 11) e dos termos do procedimento com prova (IP, navegador, SHA-256).	test_consentimentos, test_consentimento_saude, test_aceite_termo_modelo, test_pg_ddl (imutabilidade)
RNF10	Retenção automatizada (OTP, notificações, auditoria, trilha, links, logs de login, clientes inativas/excluídas, fichas de pedidos não realizados, lista de espera, registro de saúde aos 20 anos do último evento, pacote 5 anos após o fim) e esquecimento por pseudonimização, executados por procedures do Postgres; prazos LGPD fixos no settings e conferidos contra o texto publicado (aranha.W016); inventário LGPD coluna a coluna conferido por teste.	test_lgpd_retencao_saude, test_lgpd_esquecimento, test_pg_paridade (procedures), test_inventario_lgpd
RNF11	Direitos do titular pela área da cliente: acesso/portabilidade (JSON sem a ficha de saúde), pedido de correção ou exclusão com prazo, preferências e revogação de consentimento (inclusive o de saúde), e pseudonimização pela clínica.	test_politica_dsar, test_portal_cliente, test_lgpd_esquecimento
RNF12	Trilha de auditoria (log_auditoria) e trilha de dados (historico_alteracao, por trigger) com autor, IP e origem, ambas append-only no banco; a leitura de alerta de saúde nas listas do painel também vai para a auditoria; PII mascarada em logs e no Sentry (send_default_pii=False).	test_pg_historico (trilha por trigger, append-only), test_pii_sentry

4.5 Integridade

ID	Requisito	Como é verificado
RNF13	Invariantes no banco: EXCLUDE (atendimento, grade, folgas), UNIQUE parciais, CHECKs, 49 triggers (updated_at, imutabilidade de ledgers, prova de aceite, termo aceito, prontuário, anotação, item de pacote, consentimento e link; validação de consumo, de comissão e da regra de comissão usada) e FKs PROTECT no histórico clínico/financeiro.	test_pg_ddl e test_nomes_padrao no Postgres 18 do CI

4.6 Desempenho

ID	Requisito	Como é verificado
RNF16	gunicorn 1 worker × 4 threads com cache local (Redis opcional para escalar); estáticos comprimidos e com hash (WhiteNoise); índices das consultas reais, busca trigram sem acento, alertas de saúde em lote, statement_timeout na conexão e consultas lentas pelo pg_stat_statements.	test_consultas_por_tela (teto de consultas por tela), test_consultas_lentas, test_deploy_config (statement_timeout)

4.7 Observabilidade

ID	Requisito	Como é verificado
RNF17	Healthchecks /healthz/ (liveness + build do front) e /health/ (banco, cache, front); Sentry opcional; logs JSON em produção; jobs devolvem 500 (cron HTTP) ou exit 1 (serviço Cron) quando falham e avisam o	infra/test_deploy, test_deploy_config (healthchecks), infra/test_cron (falha devolve 500)

	monitor (CRON_MONITOR_URL).	

4.8 Qualidade

ID	Requisito	Como é verificado
RNF18	Cerca de 2.020 testes automatizados em 124 arquivos, num runner só (manage.py test); CI com SQLite, Postgres 18 (conformidade do padrão SQL, trilha e paridade das funções com o Python), data migrations em paralelo, build do front, wizard e painel no Chromium (Playwright), varredura visual de todas as rotas (desktop claro e celular escuro: erros de página, JS e CSP, rolagem lateral e acessibilidade pelo axe-core), imagem Docker com smoke do pre-deploy e do start, pip-audit, npm audit e gitleaks bloqueantes; ruff, import-linter, mypy nos services e cobertura combinada (SQLite + Postgres) com catraca (≈ 87 %).	CI com 9 jobs obrigatórios e catraca de cobertura combinada

4.9 Usabilidade

ID	Requisito	Como é verificado
RNF19	Interface pt-BR em tom de estética e bem-estar, em caixa de frase; contraste AA nos tokens, foco visível, formulários acessíveis, diálogos nativos e respeito a prefers-reduced-motion; telas da equipe num design system de componentes (texto base de 15px, nada abaixo de 12px, abas acessíveis, tabela que vira cartões no celular); wizard com as etapas visíveis e botão Continuar fixo no celular, operável por teclado; tema claro/escuro automático; fontes locais; fotos responsivas (WebP com JPEG de reserva, dimensões reservadas); PWA instalável para o site e para a equipe.	test_a11y_front, test_crawl_visual (axe-core em todas as rotas, desktop claro e celular escuro)

4.10 Manutenibilidade

ID	Requisito	Como é verificado
RNF20	Camadas views → services/utils → models e áreas de views independentes verificadas por import-linter; fontes únicas (services/agenda, services/atendimento, SlotService, preços, Branding, termos, consentimentos); recusas tipadas (RegraDeNegocio); contrato JSON único (utils/respostas) e telefone numa fonte só (utils/telefone); Django Forms no painel; componentes cotton e Alpine CSP; textos que também são regra (política de privacidade, FAQ) gerados das constantes (conteudo/); documentação viva e requisitos gerados a partir de dados versionados.	import-linter (contratos de camada) no CI; test_deploy_config (runner único); test_openapi (contrato JSON)
RNF23	Padrão SQL em todas as tabelas (nomes snake_case PT-BR, prefixos pk_/fk_/uq_/ck_/ix_/ex_/tg_/fn_, ON DELETE real, COMMENT em toda tabela, defaults no banco) e metadados de linha iguais em todas, em inglês: created_at em toda tabela, updated_at (por trigger) onde há UPDATE de negócio, deleted_at no soft delete e autoria created_by_id + created_by_name; conferido por teste no pg_catalog e nos models.	test_nomes_padrao (pg_catalog no Postgres) e MetadadosDeLinhaTests (sem banco)

4.11 Implantação

ID	Requisito	Como é verificado
RNF21	Imagem Docker multi-stage (Node para o front, Python para a app) com dependências fixadas (requirements.lock), usuário não-root sem shell, código só leitura, sem curl e healthcheck; deploy no Railway com pre-deploy de migração e criação do ADMIN e um serviço Cron para os jobs.	job "Imagem de produção" do CI (build, pre-deploy e start)

4.12 Documentação

ID	Requisito	Como é verificado
RNF24	Contrato das rotas de máquina em OpenAPI 3.1 (aranha_estetica/api/openapi.yaml) navegável no Swagger UI do painel; respostas JSON num envelope único {ok, codigo, mensagem}; diagramas UML, modelo de dados e documentos do projeto gerados a partir do código, sem cópia manual de contagens.	test_openapi (especificação válida, toda rota JSON documentada); geradores de documentação e UML a partir do código

5. Casos de uso

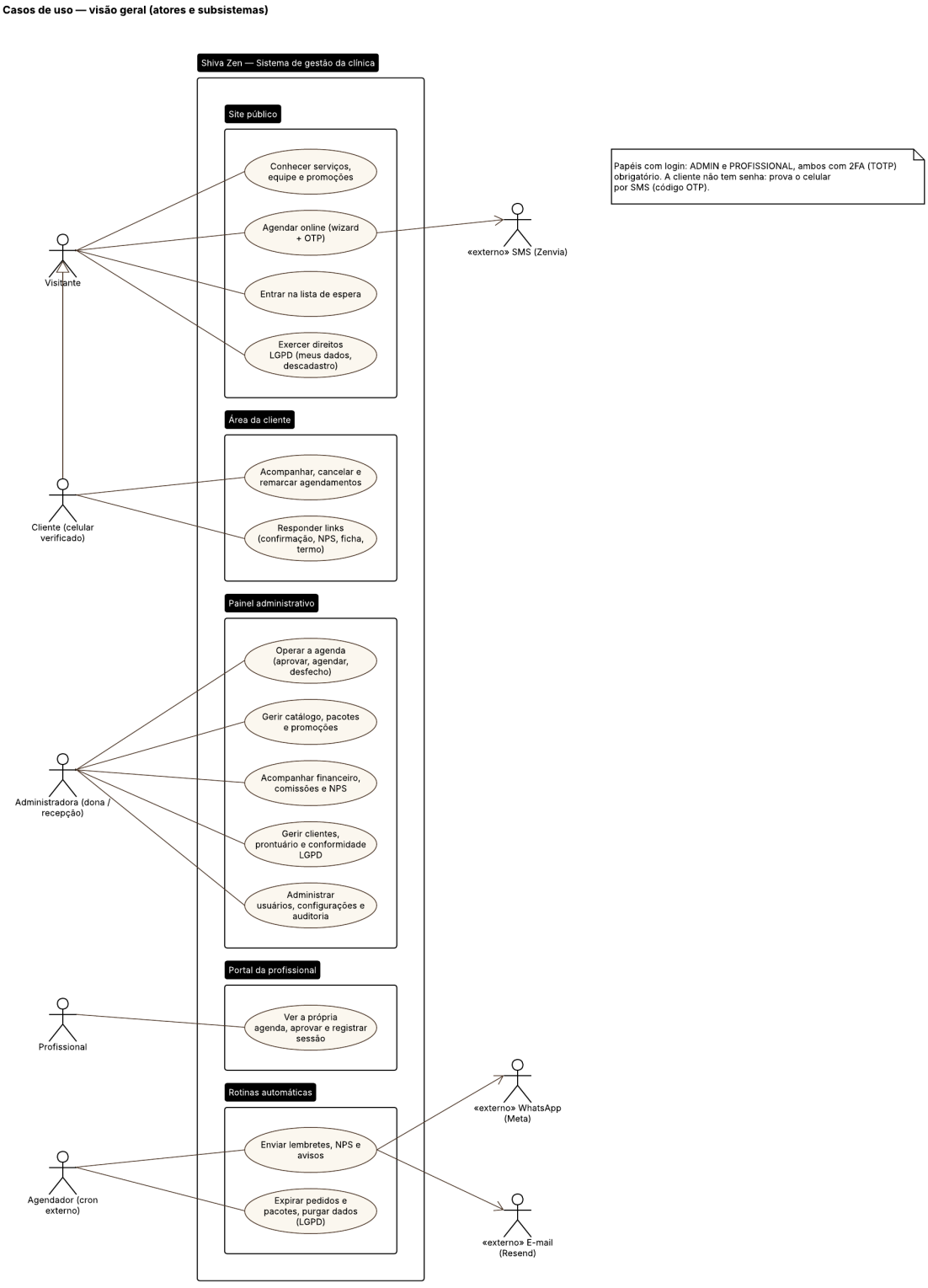


Figura 1 — Casos de uso — visão geral (atores e subsistemas).

ID	Caso de uso	Atores	Inclui
UC01	Agendar online	Visitante / Cliente (público, sem login), Cliente cadastrada, Serviços externos	UC02, UC03
UC02	Verificar celular por OTP	Visitante / Cliente (público, sem login), Cliente cadastrada, Serviços externos	—
UC03	Consultar disponibilidade	Visitante / Cliente (público, sem login)	—
UC04	Reagendar atendimento	Cliente cadastrada	UC03
UC05	Cancelar atendimento	Cliente cadastrada	—
UC06	Entrar em Meus agendamentos	Cliente cadastrada, Serviços externos	UC02
UC07	Confirmar presença	Cliente cadastrada	—
UC08	Entrar na lista de espera	Visitante / Cliente (público, sem login)	—
UC09	Responder ficha de anamnese por link	Visitante / Cliente (público, sem login)	—
UC10	Responder NPS	Cliente cadastrada, Serviços externos	—
UC11	Aceitar termo por link	Cliente cadastrada	—
UC12	Exercer direitos LGPD	Cliente cadastrada, Serviços externos	UC02
UC13	Autenticar equipe	Administrador (ADMIN), Profissional	UC14
UC14	Cadastrar / validar 2FA	Administrador (ADMIN), Profissional	—
UC15	Operar o portal do profissional	Profissional	—
UC16	Gerir agendamentos no painel	Administrador (ADMIN)	—
UC17	Gerir clientes e prontuário	Administrador (ADMIN), Profissional	UC29
UC18	Gerir profissionais e disponibilidade	Administrador (ADMIN)	—
UC19	Gerir pacotes	Administrador (ADMIN)	—
UC20	Gerir promoções e campanhas	Administrador (ADMIN), Serviços externos	—
UC21	Financeiro e comissões	Administrador (ADMIN)	—
UC22	Gerir lista de espera	Administrador (ADMIN), Serviços externos	—
UC23	Gerir formulários e termos	Administrador (ADMIN)	—
UC24	Administrar o sistema	Administrador (ADMIN)	—
UC25	Executar jobs periódicos	Sistema / Cron externo, Serviços externos	—
UC26	Receber webhooks	Serviços externos, Sistema / Cron externo	—
UC27	Agendar pela recepção	Administrador (ADMIN)	UC03
UC28	Moderar depoimentos	Administrador (ADMIN)	—
UC29	Gerir autorizações de comunicação	Administrador (ADMIN)	—
UC30	Assinar o feed iCal da agenda	Profissional, Administrador (ADMIN)	—
UC31	Consultar minhas comissões	Profissional	—
UC32	Contatar a clínica pelo site	Visitante / Cliente (público, sem login)	—
UC33	Revogar o consentimento de saúde	Cliente cadastrada, Administrador (ADMIN)	UC06

6. Matriz de rastreabilidade

Cada requisito funcional com os casos de uso que o realizam e as regras de negócio que ele aplica. "—" em caso de uso marca o requisito transversal (exibição, trilha automática), sem interação própria.

RF	Prioridade	Casos de uso	Regras de negócio
RF01	Essencial	—	RN28, RN34, RN57
RF02	Essencial	UC01 Agendar online, UC02 Verificar celular por OTP, UC03 Consultar disponibilidade, UC08 Entrar na lista de espera	RN03, RN04, RN06, RN07, RN08, RN09, RN10, RN11, RN18, RN19
RF03	Essencial	UC01 Agendar online, UC09 Responder ficha de anamnese por link	RN14, RN15, RN16, RN17
RF04	Essencial	UC06 Entrar em Meus agendamentos, UC02 Verificar celular por OTP	RN18, RN19
RF05	Essencial	UC04 Reagendar atendimento, UC03 Consultar disponibilidade	RN21
RF06	Essencial	UC05 Cancelar atendimento	RN22, RN52
RF07	Importante	UC07 Confirmar presença	RN23, RN47, RN52
RF08	Importante	UC11 Aceitar termo por link	RN16, RN39, RN47
RF09	Importante	UC08 Entrar na lista de espera	RN32
RF10	Importante	UC10 Responder NPS	RN33, RN34
RF11	Essencial	UC09 Responder ficha de anamnese por link	RN15, RN36, RN47
RF12	Essencial	UC12 Exercer direitos LGPD, UC26 Receber webhooks	RN17, RN42
RF13	Desejável	UC01 Agendar online	RN06
RF14	Essencial	UC13 Autenticar equipe, UC14 Cadastrar / validar 2FA	RN44, RN45
RF15	Essencial	UC16 Gerir agendamentos no painel, UC15 Operar o portal do profissional	RN11, RN20
RF16	Essencial	UC27 Agendar pela recepção, UC03 Consultar disponibilidade	RN12, RN13
RF17	Essencial	UC16 Gerir agendamentos no painel	RN20, RN24, RN29
RF18	Essencial	UC15 Operar o portal do profissional	RN20, RN37, RN38
RF19	Essencial	UC17 Gerir clientes e prontuário	RN36, RN37, RN48
RF20	Essencial	UC17 Gerir clientes e prontuário	RN02, RN05, RN38
RF21	Essencial	UC18 Gerir profissionais e disponibilidade	RN09, RN28, RN46
RF22	Importante	UC19 Gerir pacotes	RN26, RN27, RN54
RF23	Importante	UC20 Gerir promoções e campanhas	RN17, RN28, RN35
RF24	Importante	UC21 Financeiro e comissões	RN29, RN30
RF25	Desejável	UC28 Moderar depoimentos	RN33, RN34
RF26	Importante	UC22 Gerir lista de espera	RN32
RF27	Essencial	UC23 Gerir formulários e termos	RN16, RN36, RN39
RF28	Essencial	UC24 Administrar o sistema	RN01, RN51
RF29	Essencial	UC25 Executar jobs periódicos	RN23, RN33, RN40, RN49, RN50
RF30	Importante	UC16 Gerir agendamentos no painel, UC27 Agendar pela recepção	RN25
RF31	Essencial	UC15 Operar o portal do profissional, UC16 Gerir agendamentos no painel	RN20, RN24, RN25, RN26, RN30, RN31
RF32	Importante	UC26 Receber webhooks	RN17, RN33
RF33	Importante	UC29 Gerir autorizações de comunicação	RN17
RF34	Desejável	UC30 Assinar o feed iCal da agenda	RN47
RF35	Essencial	UC25 Executar jobs periódicos	RN49
RF36	Essencial	—	RN43
RF37	Importante	UC21 Financeiro e comissões	RN30
RF38	Desejável	UC31 Consultar minhas comissões	RN30
RF39	Importante	UC06 Entrar em Meus agendamentos, UC12 Exercer direitos LGPD	RN17

RF40	Essencial	UC33 Revogar o consentimento de saúde	RN55
RF41	Essencial	UC12 Exercer direitos LGPD	RN41, RN42
RF42	Essencial	UC12 Exercer direitos LGPD	RN42
RF43	Desejável	UC32 Contatar a clínica pelo site	RN14
RF44	Essencial	—	RN39, RN56
RF45	Importante	UC16 Gerir agendamentos no painel, UC17 Gerir clientes e prontuário	RN38, RN43
RF46	Desejável	—	RN57
RF47	Desejável	—	—

7. Resumo

Indicador	Quantidade
Requisitos funcionais	47
Essencial	26
Importante	14
Desejável	7
Requisitos não funcionais	24
Segurança	6
Privacidade	2
Confiabilidade	3
LGPD	4
Integridade	1
Desempenho	1
Observabilidade	1
Qualidade	1
Usabilidade	1
Manutenibilidade	2
Implantação	1
Documentação	1
Casos de uso	33
Regras de negócio	57